MANDATE

Autonomous Procure-to-Pay with a Sealed Authority Envelope

- Track: ArmorIQ -- Problem 1 [’Autonomous, until it shouldn’t be’] & Problem 2 [Delegation]
- Team: STELLAR STACK | Team ID: team-E657F05D7F45
- Institution: AMRITA VISHWA VIDYAPEETHAM, NAGERCOIL
- Core Principle: Fix Authority at Plan Time Over Trusted Data Before Ingesting Untrusted Invoices

Slide 2 -- AI Payment Automation Has a Critical Trust Gap

Prompt injection in supplier invoices allows models to be hijacked into unauthorized payments

> The Danger: Invoice free-text advisories contain plausible bank change requests ['Remit to new HDFC A/C...'].

> The Flaw: LLMs read untrusted text and directly execute disbursement tools without proving authority.

> Limitations of Existing Tools: Prompt filters can be bypassed; RBAC is too broad; audit logs only record after the theft.

> The Requirement: A deterministic security boundary that stops unauthorized payments before the tool runs.

Slide 3 -- Mandate: Pre-Mission Authority Sealing

Transforming CFO vendor & PO data into an immutable, cryptographic Authority Envelope

- Phase 1 [Trusted Setup]: CFO defines approved vendors, payee bank accounts, open POs, and spend ceilings.
- Plan Sealing: ArmorIQ captures the plan, hashes trusted facts, and mints an immutable Intent Token.
- Phase 2 [Untrusted Intake]: Invoices and advisories are ingested only after seal and cannot mutate authority.
- Pre-Tool Verification: Sole gateway.py validates every MCP tool call against the sealed envelope.

Slide 4 -- Cryptographic Delegation Across Subagents

Capability attenuation across Controller, Matcher, and Disburser agents

- Controller Agent: Owns the root mission, creates delegation grants, and coordinates workflow.
- Matcher Agent: Granted strictly read-only capability ['fetch_invoices']; direct spend is cryptographically blocked.
- Disburser Agent: Granted 'initiate_payment' scoped strictly to approved payee accounts and PO amounts.
- FastMCP Protocol: Native FastMCP tool server executes financial mutations only upon gateway ALLOW verdict.

Slide 5 -- Deterministic Defense Against Live Attacks

Proven headline balances: Governed Rs 39,91,726 vs Ungoverned Rs 38,57,560

- Attack A [Bank Shift]: Untrusted payee 509900443322 blocked instantly -> Prevented loss: Rs 46,200.00.
- Attack B [Capability Bypass]: Matcher direct payment blocked with CAPABILITY_NOT_DELEGATED.
- Attack C [10x Amount Spike]: Over-PO payment blocked with AMOUNT_EXCEEDS_PO_AND_CEILING.
- Legitimate Over-Ceiling: Rs 1,45,000 payment paused for human CFO review and resumed via ArmorIQ re-auth.

Slide 6 -- Judge Challenge Mode: Live Proving Ground

Deployable, zero-CLI interactive proving ground for hackathon evaluators

- Sandbox Isolation: Evaluators create independent procurement missions with custom vendors, POs, and ceilings.
- Real Gateway Path: Custom Security Probes dispatch typed proposals directly through gateway.py -> ArmorIQ.
- Visual Forensics: Trust Boundary Map highlights exact authority conflicts; Counterfactual Proof displays prevented losses.
- Authority Cliff Replay: Visualizes execution halting at the boundary with header ’AUTHORIZED BY: NOBODY’.

Slide 7 -- Economic Impact & Submission Disclosure

Team STELLAR STACK -- AMRITA VISHWA VIDYAPEETHAM, NAGERCOIL

- Financial Protection: Zero balance drift under adversarial attack; Rs 1,34,166.00 in total fraud loss prevented.
- Zero Secret Leakage: Private signing keys and credentials remain strictly server-side inside Python backend.
- Transparent Architecture: LocalEnforcer simulation implements 100% generic policy matching the ArmorIQ contract.
- Verified Test Suite: 28/28 automated invariant & Judge Mode tests passing in continuous integration.